

RGPD : Règlement Général sur la Protection des Données

X-Corp:

Acteurs du traitement:

<u>Acteur</u>	<u>Rôle chez X-Corp</u>
Responsable du traitement	X-Corp, qui détermine les finalités (personnalisation d'offres, suivi de patients, suivi pédagogique) et les moyens (DataManage, MarketInsight, AutoMail) des traitements réalisés pour ses clients RetailCo, HealthMed et EduLearn.
Sous-traitants	CloudSecure (hébergement et stockage cloud sécurisé des données) et AdBoost (diffusion de publicité ciblée à partir de segments transmis par X-Corp). Ces prestataires traitent des données pour le compte de X-Corp et doivent être liés par un contrat de sous-traitance conforme à l'article 28 du RGPD.
Personnes concernées	Les clients de RetailCo (≈800 000), les patients de HealthMed (≈500 000) et les utilisateurs d'EduLearn (≈300 000), dont les données transitent par les outils de X-Corp.
DPO (Délégué à la Protection des Données)	Un DPO a été désigné chez X-Corp ; il supervise la conformité, conseille sur les DPIA et constitue le point de contact avec la CNIL et les personnes concernées.
Autorité de contrôle	La CNIL, le siège social de X-Corp se situant à Paris.

Bases légales mobilisées:

L'article 6 du RGPD impose qu'un traitement repose sur une base légale parmi les six prévues. X-Corp mobilise principalement le consentement (article 6-1-a) pour l'ensemble de ses traitements :

- **RetailCo — DataManage** : Personnalisation des offres et promotions pour les clients de RetailCo, sur la base du consentement recueilli lors de l'inscription ou de l'achat.
- **HealthMed — DataManage** : Suivi des traitements et rappels de rendez-vous pour les patients de HealthMed, sur la base du consentement explicite (renforcé, car il s'agit de données de santé, catégorie particulière au sens de l'article 9).
- **EduLearn — MarketInsight** : Amélioration des parcours pédagogiques et recommandations de cours, sur la base du consentement des utilisateurs.
- **AutoMail** : Envoi de campagnes emailing ciblées, où le consentement doit être spécifique à la finalité marketing et distinct des autres consentements (opt-in dédié), conformément à la directive ePrivacy et au RGPD.

Evaluation des risques:

- **Risque lié à la sensibilité des données** : Les données de santé traitées pour HealthMed relèvent de l'article 9 (catégories particulières de données) et exposent les patients à un risque élevé en cas de fuite.
- **Risque lié à l'anonymisation** : MarketInsight utilise l'IA pour prédire des tendances et segmenter les audiences, ce qui peut conduire à des décisions individuelles automatisées ou à une atteinte à la vie privée par recoupement de données comportementales.

- **Risque de violation de données** : X-Corp a déjà subi une fuite de données exposant 2 000 enregistrements clients, révélant des lacunes dans le processus de réponse aux incidents — un risque de récurrence existe tant que ce processus n'est pas renforcé.
- **Risque organisationnel** : Le volume important de demandes de droit d'accès (50 à 100 par mois) et les difficultés de gestion des consentements marketing traduisent un risque de non-conformité procédurale.

Concepts clés:

“ Les concepts clés du RGPD régissent la manière dont les données à caractère personnel sont collectées, stockées et gérées. Ces concepts et principes sont au cœur du RGPD. Ils permettent aux personnes physiques d'exercer un meilleur contrôle sur les informations à caractère personnel les concernant et garantissent que les organisations traitent les données à caractère personnel de manière responsable. “

https://www.edpb.europa.eu/topics/key-gdpr-concepts_fr

1. Licéité du traitement (RGPD - article 6)

Un traitement de données personnelles n'est licite que s'il repose sur au moins une des six bases prévues par le RGPD : consentement, exécution d'un contrat, obligation légale, sauvegarde des intérêts vitaux, mission d'intérêt public, ou intérêt légitime.

-> **Exemple:** X-Corp fonde la quasi-totalité de ses traitements (RetailCo, HealthMed, EduLearn) sur le consentement des personnes concernées, recueilli à l'inscription ou à l'achat.

2. Finalité du traitement

Les données doivent être collectées pour des **finalités déterminées, explicites et légitimes**, et ne peuvent ensuite être traitées d'une manière incompatible avec ces finalités initiales.

-> **Exemple:** Les données collectées via DataManage pour personnaliser les offres de RetailCo ne peuvent pas être réutilisées par MarketInsight pour prédire des tendances de marché sans nouvelle base légale ou information des personnes concernées, sous peine de détournement de finalité.

3. Minimisation des données

Seules les données **strictement nécessaires** à la finalité poursuivie doivent être collectées et traitées.

-> **Exemple:** Pour la segmentation d'audience réalisée par MarketInsight, X-Corp doit s'assurer de ne collecter que les données comportementales pertinentes (pages visitées, interactions) et éviter des données superflues comme la géolocalisation précise si elle n'est pas utile à la finalité marketing.

4. Protection particulière des données sensibles (RGPD - article 9)

Certaines catégories de données (santé, origine raciale ou ethnique, opinions politiques, données biométriques, etc.) bénéficient d'une **protection renforcée** et ne peuvent être traitées que dans des cas limitativement énumérés, avec le consentement explicite de la personne.

-> **Exemple:** Les données de santé et l'historique médical traités pour HealthMed relèvent de cette catégorie : X-Corp doit recueillir un consentement explicite (déjà en place) et appliquer des mesures de sécurité renforcées, ce qui justifie la pseudonymisation et le chiffrement AES-256 déployés.

5. Conservation limitée des données

Les données ne doivent pas être conservées au-delà de la durée nécessaire à la finalité pour laquelle elles ont été collectées ; des durées de conservation précises doivent être définies et justifiées.

-> **Exemple:** X-Corp applique des durées différenciées selon le client : 5 ans après le dernier contact pour RetailCo, 10 ans après la fin du traitement médical pour HealthMed (durée alignée sur les obligations légales du secteur de la santé), et 2 ans après la fin d'utilisation pour EduLearn, avec une revue de la politique de conservation tous les 2 ans.

6. Obligation de sécurité (RGPD - article 32)

Le responsable de traitement doit mettre en œuvre des mesures techniques et organisationnelles adaptées au risque, afin de **garantir la confidentialité, l'intégrité et la disponibilité** des données.

-> **Exemple:** X-Corp a déployé plusieurs mesures : pseudonymisation des données sensibles, chiffrement en transit et au repos (AES-256), authentification à deux facteurs pour les accès internes, et contrôle d'accès basé sur les rôles (RBAC) limitant l'accès aux données strictement nécessaires à chaque fonction.

7. Transparence

Les personnes concernées doivent recevoir une **information claire, accessible et compréhensible** sur la manière dont leurs données sont collectées et utilisées (identité du responsable de traitement, finalités, durées de conservation, droits, destinataires).

*-> **Exemple:** Les clients de RetailCo, les patients de HealthMed et les utilisateurs d'EduLearn doivent être informés, via une politique de confidentialité claire au moment de la collecte, de l'usage fait de leurs données par DataManage, MarketInsight et AutoMail, ainsi que du recours à des sous-traitants comme CloudSecure et AdBoost.*

8. Droits des personnes

Le RGPD garantit aux personnes un ensemble de droits sur leurs données : droit d'accès, de rectification, d'effacement, à la limitation du traitement, à la portabilité, d'opposition, et droit de ne pas faire l'objet d'une décision entièrement automatisée.

*-> **Exemple:** X-Corp reçoit entre 50 et 100 demandes de droit d'accès par mois, ce qui constitue un volume significatif à traiter dans le délai légal d'un mois ; un processus dédié et outillé est nécessaire pour répondre efficacement, notamment pour les demandes concernant les données de santé gérées pour HealthMed.*